Studio Nx

Backend(FastAPI/Python) 34 — POST /api/v1/auth/logout

2026-10-12

Backend(FastAPI/Python) 34 — 라우터 `POST /api/v1/auth/logout`

항목	내용
파일	`studionx/backend/app/api/v1/auth.py` (함수 이름 `logout`)
작업	P1-05 로그인: 로그아웃 (PRD 01 FR-104, P1-05 마지막 함수)
작성	Claude (AI), 2026-10-07, 사용자 검토
이전 · 다음	33 `POST /auth/refresh` · (P1-05 끝) · 실제 사이트 시험 ai-note 37

1. 하는 일

리프레시 쿠키를 **지우라는 응답**을 보냅니다. 본문 없이 204로 응답합니다.

```
POST /api/v1/auth/logout

→ 204 No Content
Set-Cookie: snx_refresh=""; expires=(지금); HttpOnly; Max-Age=0; Path=/api/v1/auth; SameSite=lax
```

토큰	로그아웃할 때 지우는 쪽
Refresh (쿠키)	**이 라우터**입니다. JS는 `HttpOnly` 쿠키를 지울 수 없어서 서버가 지워야 합니다
Access (JS 메모리)	화면 `logout()`의 `clearAccessToken()` 입니다 (JS 08)

2. 언제 쓰나

헤더의 **Sign Out** 버튼을 누르면 JS 08 `logout()`이 이 API를 부릅니다.

순서	화면 또는 서버	일어나는 일
①	`logout()`	`api.post('/auth/logout', undefined, { auth: false })`를 보냅니다
②	**이 라우터**	204로 응답하면서 쿠키를 지웁니다
③	`logout()`	`clearAccessToken()`을 부르고 `home.html`로 이동합니다
④	다음에 사이트를 열면	쿠키가 없어서 재발급(33)이 401이 되고, 로그인하지 않은 상태가 됩니다

ai-note 34(P1-02, 03 실제 사이트 시험)에서 `/auth/logout → 500`이었던 결과가 이제 204가 됩니다. (그때도 `logout()`은 실패를 무시하고 홈으로 갔지만, 쿠키는 남아 있었습니다.)

3. 코드

import (파일 맨 위: 32번, 33번과 같고, 이번에 새로 추가한 것은 없습니다)

```
from fastapi import APIRouter, Cookie, Query, Response, status
…
```

이 함수는 **`Response`와 `status`**를 쓰고, 쿠키를 지우는 일은 31번 `clear_refresh_cookie()`에 맡깁니다.

함수

```
@router.post("/logout", status_code=status.HTTP_204_NO_CONTENT)
def logout(response: Response) -> None:
    clear_refresh_cookie(response)
```

문법 풀이

import 문법	뜻
`from fastapi import status`	상태 번호에 이름을 붙여 둔 모음입니다 (`HTTP_204_NO_CONTENT` = 204)

식	뜻
`status_code=204`	성공했지만 **본문이 없다**는 뜻입니다
`-> None`	돌려줄 본문이 없습니다
`response: Response`	여기에 붙인 쿠키 삭제 헤더가 204 응답에 실립니다
`db`와 `user` 인자가 없음	로그인 확인도 하지 않고, DB도 쓰지 않습니다

4. 흐름

1. 31번으로 "지금 만료되는" 쿠키를 응답에 붙입니다.
2. 204로 응답합니다.

5. 왜 이렇게

선택	이유
로그인 확인 없이 받음 (템플릿 권장)	Access Token이 이미 만료된 상태에서 Sign Out을 눌러도 쿠키는 지워져야 합니다. 하는 일이 "쿠키 지우기"뿐이라서 누가 불러도 위험하지 않습니다
서버에 아무것도 기록하지 않음	토큰을 서버에 저장하지 않는 방식(JWT)이기 때문입니다. 남아 있는 Access Token은 길어야 30분 뒤에 스스로 만료됩니다
204로 응답	돌려줄 내용이 없다는 표준 응답입니다. `api.js`는 204를 `null`로 처리합니다 (JS 02)

참고 (쿠키를 훔쳐 간 경우): 로그아웃은 **이 브라우저**의 쿠키만 지웁니다. 이미 복사해 간 리프레시 토큰은 3일 동안 유효합니다. 이것을 막으려면 서버에 "무효 토큰 목록"을 두거나, 비밀번호를 바꿀 때 모든 토큰을 끊는 기능이 필요합니다. Phase 1 범위 밖이라서 나중에 검토합니다.

6. 시험 (`tests/test_auth_routes.py`에 3개를 추가해서 모두 43개, 실제 앱과 MySQL로 실행)

시험	확인한 것
로그인 → 로그아웃 → 재발급	로그아웃 전 재발급은 200이고, 로그아웃은 204에 본문이 없으며 `snx_refresh=""; Max-Age=0; Path=/api/v1/auth` 헤더가 붙습니다. 로그아웃 뒤 재발급은 401입니다
로그인하지 않은 상태	204
엉터리 `Authorization` 헤더	204입니다 (로그인 확인을 하지 않습니다)

전체 시험 234개가 통과했고, `ruff` 검사도 통과했습니다. 인증 관련 파일(`auth.py`, `security.py`, `auth_service.py`)에 남은 `NotImplementedError`는 0개입니다.